Threat Intelligence Report: Honeypot Environment Analysis

Document ID: SOC-IR-2026-11-03

Date: November 3, 2026

Author: Yevhenii Shevchenko

Status: Final

TLP (Traffic Light Protocol): TLP:CLEAR

1. Executive Summary

Over a 24-hour monitoring period (November 2–3, 2026), a Honeypot environment based on the T-Pot architecture was deployed in the Microsoft Azure cloud. The objective of this deployment was to collect telemetry on current "spray-and-pray" attack vectors, botnet activity, and vulnerability scanning on the public Internet.

During the observation period, **17,103 malicious events** were recorded. The vast majority of the attack traffic was directed at compromising the SSH service (TCP port 22) through automated credential stuffing and brute-force attacks. Furthermore, targeted exploitation attempts against the critical vulnerability CVE-2024-6387 (regreSSHion) were actively detected.

2. Scope and Environment Configuration

- **Platform:** Microsoft Azure (Region: Sweden Central)
- **Sensor Architecture:** T-Pot CE (Debian 13)
- **Core SIEM / IDS:** ELK Stack (Elasticsearch, Logstash, Kibana), Suricata
- **Active Honeypot Modules:** Cowrie (SSH/Telnet), Ciscoasa, etc.
- **Exposed Ports:** All (Any/Any) to capture a maximum spectrum of threats.

3. Traffic Analysis & Telemetry

3.1. General Distribution

- **Total Attacks Logged:** 17,103
- **Peak Activity Window:** November 3, 00:00 - 06:00 (Kyiv Time).
- **Most Attacked Service:** SSH (Cowrie Honeypot).

3.2. Geographic Distribution (Top 3 Countries)

1. **Bulgaria:** 1,245 incidents
2. **Philippines:** 685 incidents
3. **United States:** 677 incidents

3.3. Threat Actor Infrastructure (Top ASNs)

Adversaries primarily utilized rented or compromised hosts from the following Autonomous Systems:

1. **AS 198364 (Banatsync Srl):** 9,717 events
2. **AS 142271 (EWS DS Networks Inc):** 3,572 events
3. **AS 61173 (Green Web Samaneh):** 2,417 events

4. Tactics, Techniques, and Procedures (TTPs)

Aligned with the **MITRE ATT&CK** framework, the observed malicious activity can be classified under the following techniques:

- **T1110.001 - Brute Force: Password Guessing:** Threat actors heavily relied on automated scripts utilizing predefined dictionaries to guess credentials.
    - *Top 3 Usernames targetted:* `root`, `ubuntu`, `admin`
    - *Top 5 Passwords attempted:* `123456`, `password`, `123`, `1234`, `1`
- **T1190 - Exploit Public-Facing Application:** The Suricata IDS flagged 6 exploitation attempts targeting **CVE-2024-6387 (regreSSHion)**. This vulnerability allows for unauthenticated Remote Code Execution (RCE) on servers running outdated OpenSSH versions via a race condition in `SIGALRM` handlers.
- **T1046 - Network Service Discovery:** Mass port scanning and service fingerprinting were conducted using Go-based tools and Nmap.
    - *Related Suricata Alerts:* `ET INFO SSH-2.0-Go version string Observed`, `ET SCAN NMAP -sS window 1024`.

5. Indicators of Compromise (IoCs)

5.1. Top Malicious IP Addresses (Sources)

It is highly recommended to ingest the following IP addresses into perimeter firewall blocklists:

IP Address	Event Count	Classification (Reputation)	Country
`109.160.32.154`	5,995	SSH Abuse / Brute-force	Bulgaria
`154.18.197.29`	3,572	Scan Source	Philippines
`77.239.124.35`	2,508	Scan Source	United States
`193.141.127.102`	2,417	SSH Abuse	Iran
`77.239.124.45`	1,214	Scan Source	United States

6. Mitigation & Recommendations

Based on the analyzed traffic, the following proactive defense measures are recommended to protect a real-world corporate infrastructure from similar threats:

1. **Disable Password Authentication:** Disable password-based logins for SSH (`PasswordAuthentication no` in `sshd_config`) and enforce public key authentication (e.g., Ed25519/RSA keys).
2. **Disable Root Access:** Prevent direct login for the superuser by setting `PermitRootLogin no`.
3. **Patch Management:** Immediately update OpenSSH packages on all public-facing servers to remediate CVE-2024-6387.
4. **IP Allowlisting:** Restrict access to TCP port 22 strictly to trusted IP addresses or require corporate VPN access for management.
5. **Implement Fail2Ban / CrowdSec:** Deploy automated intrusion prevention tools to temporarily block IP addresses after 3–5 failed authentication attempts.